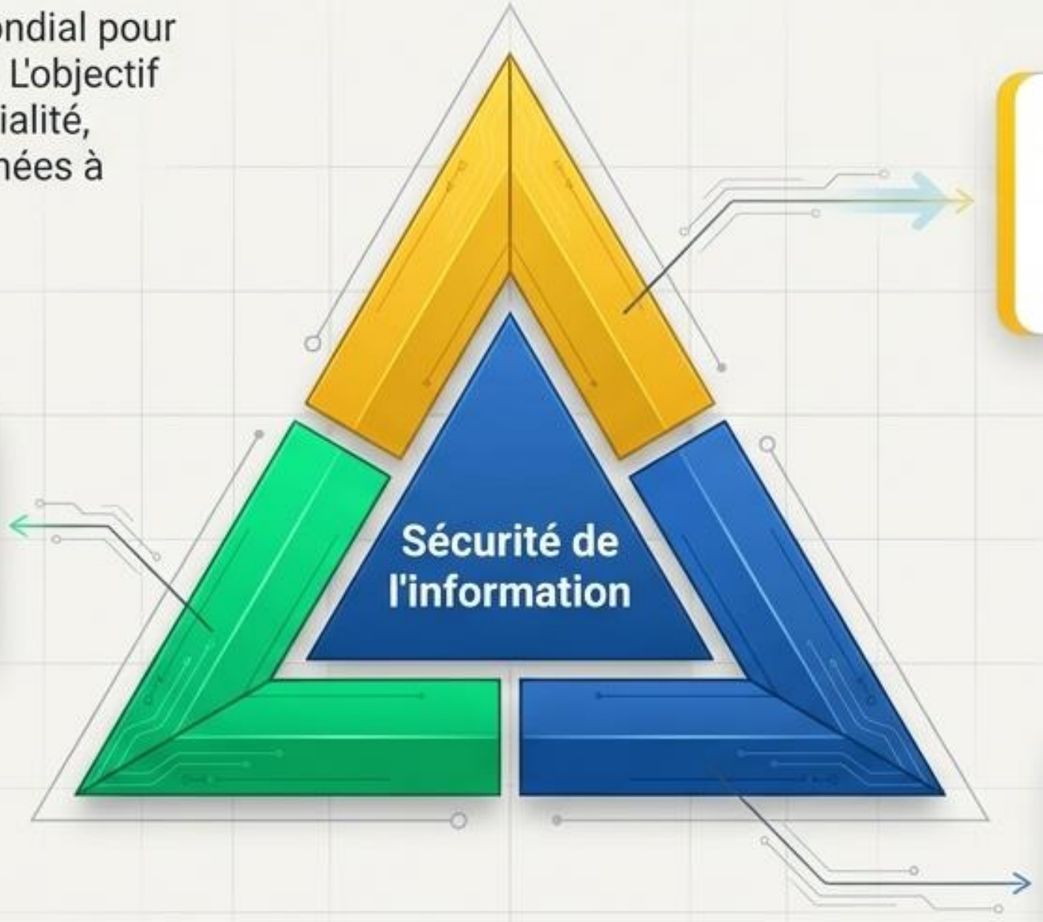
Sécurité de l’Internet des Objets (IoT)

De la vulnérabilité MQTT à l’implémentation TLS & Norme ISO 27001

Le Cadre de Confiance (ISO/IEC 27001)

L'ISO/IEC 27001 fournit un cadre mondial pour protéger les informations sensibles. L'objectif principal est de garantir la confidentialité, l'intégrité et la disponibilité des données à travers des contrôles adaptés.



Confidentialité

Protection contre les accès non autorisés.

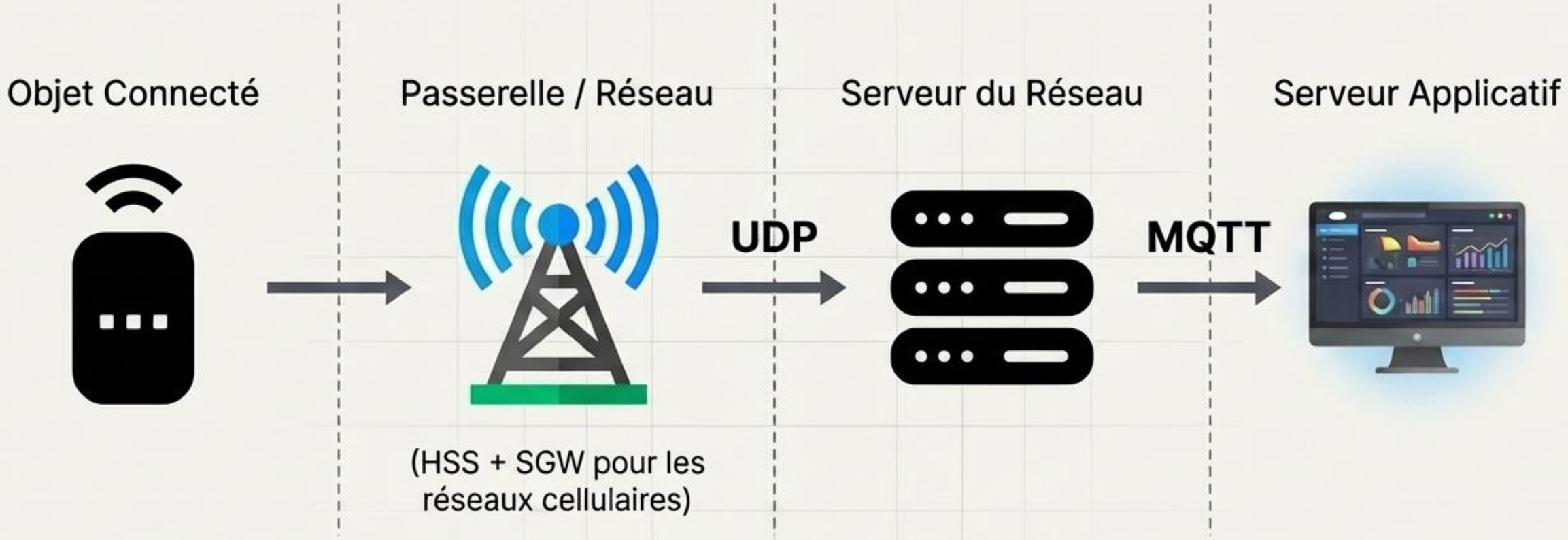
Intégrité

Protection contre l'altération des données.

Disponibilité

Garantie de l'accès à l'information en cas de besoin.

Synoptique de la Chaîne de Valeur IoT



La sécurité doit être garantie à chaque étape de la chaîne.
Un seul maillon faible compromet l'architecture globale.

La Faille : Vulnérabilité par Défaut du Protocole MQTT

```
mosquitto_sub -h 192.168.1.25 -t '#' -v
```

Le protocole MQTT standard transmet les données sur internet sans aucune protection. Les attaques potentielles permettent d'intercepter les identifiants et d'observer le trafic réseau.

Preuve à l'Appui : L'Analyse Wireshark

```
mosquitto_sub -h 192.168.1.18 -u ciel -P passciel -t 'home/bedroom'
```

```
> Frame 1126: 84 bytes on wire (672 bits), 84 bytes captured (672 bits) on interface 0
> Ethernet II, Src: 0a:59:c2:73:ec:04 (0a:59:c2:73:ec:04), Dst: 78:4f:43:6c:f5:bb (78:…
> Internet Protocol Version 4, Src: 192.168.1.25, Dst: 192.168.1.39
> Transmission Control Protocol, Src Port: mqtt (1883), Dst Port: 50196 (501196), Seq: …
> MQ Telemetry Transport Protocol

0000   78 4f 43 6c f5 bb 0a 59  c2 73 ec 04 08 00 45 00   xOCL...Y .s...E.
0010   01 26 27 3a 40 00 01 01  38 0a c0 b8 5a 19 66 09   .F..@.@. e...^.f
0040   4a 7f 30 10 00 0c 68 6f  6d 65 2f 62 65 64 72 6f   J.0...home/bedro
0050   6f 6d 32 31                                        om21
```

Télémétrie en clair

```
> Frame 715: 96 bytes on wire (768 bits), 86 bytes captured (768 bits) on interface 0
> Ethernet II, Src: 78:4f:43:6c::f5:bb (78:4f:43:6c:f5:bb), Dst: 40:9c:a7:68:6:6b:e4 (40:…
> Internet Protocol Version 4, Src: 192.168.5.88, Dst: 192.168.5.18
> Transmission Control Protocol, Src Port: 52223 (52323), Dst Port: mqtt (18833), Seq: …
> MQ Telemetry Transport Protocol

0000  40 9c a7 68 6b be e4 78 4f   43 6c f5 bb 08 00 45 00   @..hk.x0 Cl....E.
0010  00 52 00 00 00 00 00 40 06   ee eb c0 a8 05 58 c0 a8   .R....@. .....X..
0020  05 12 cc 63 07 5b 00 01 a8   ff 18 ee ef b9 18 80 18   ...c.[.. ........
0050  00 04 63 69 69 65 6c 00 08   70 61 73 73 63 69 65 6c   ..ciel.. passciel
```

Identifiants en clair

Les données de télémétrie ET le couple identifiant/mot de passe sont lisibles en clair sur le réseau.

La Contre-Mesure : L'Arsenal Cryptographique

Confidentialité

Chiffrement Symétrique

- **Algorithmes :** AES, ChaCha20
- **Cas d'usage :** Chiffrement direct des messages.
- **Avantage :** Très rapide.

Chiffrement Asymétrique

- **Algorithmes :** RSA, ECDSA, DHE
- **Cas d'usage :** Échange de clés et vérification de certificats.
- **Mécanisme :** La clé publique chiffre, seule la clé privée déchiffre.

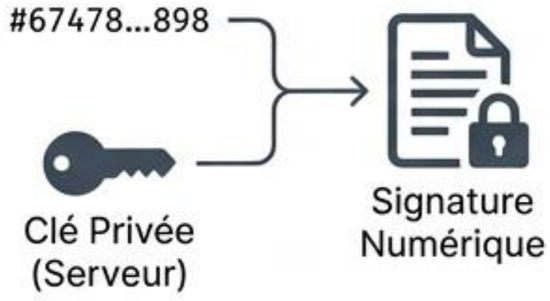
Garantir l'Intégrité et l'Authenticité

Intégrité + Authenticité

Étape 1 : Le Hachage

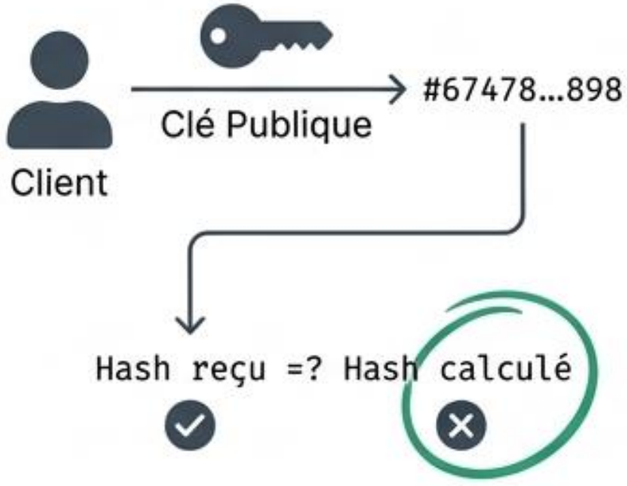
Intégrité

Étape 2 : La Signature



Intégrité + Authenticité

Étape 3 : La Vérification



L'Autorité de Certification (CA)

Intégrité + Authenticité

Un CA est une entité de confiance tierce qui délivre des certificats numériques (PKI). Il utilise sa clé privée pour signer le certificat du serveur (algorithme de hachage + signature), garantissant ainsi la sécurité des communications SSL/TLS.

```
Exemples Reconnus : Let's Encrypt, DigiCert, GlobalSign, Entrust.
```

Anatomie et Vérification d'un Certificat TLS

Constitution d'un Certificat

- ✓ Nom de Domaine
- ✓ Organisation
- ✓ Autorité de Certification (CA)
- ✓ Période de Validité
- ✓ Numéro de Série
- ✓ Signature du CA
- ✓ Clé Publique du Serveur

Le Magasin de Confiance

Windows

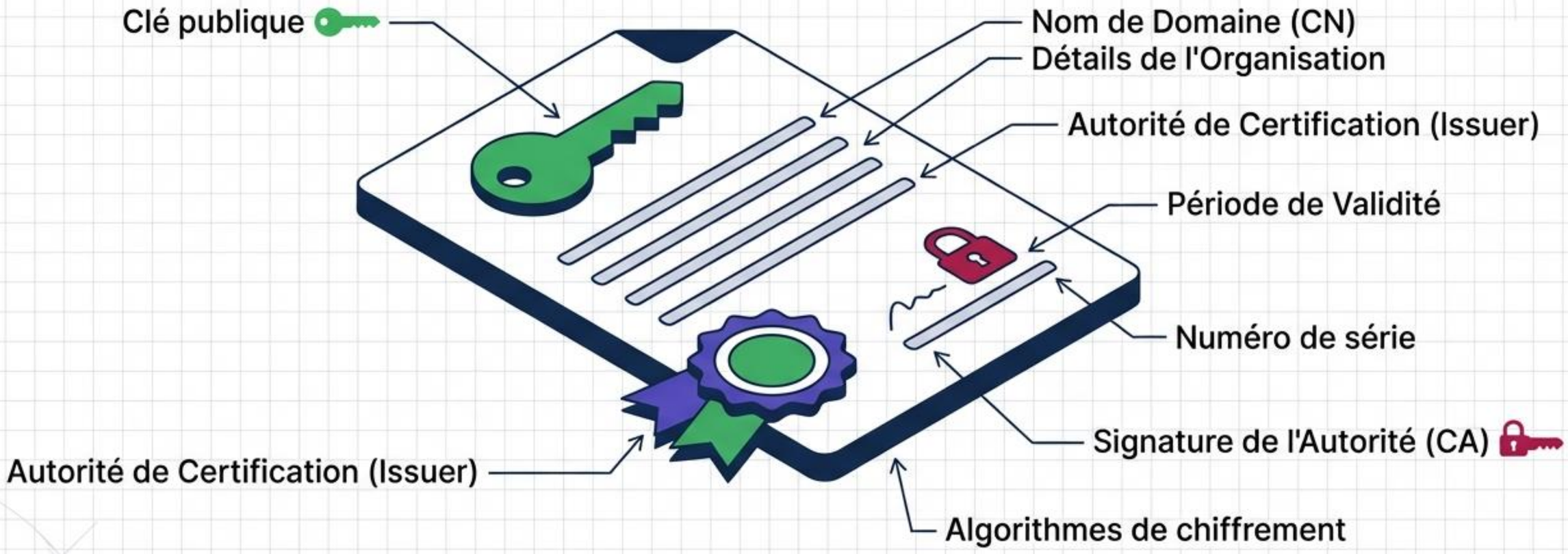
`C:\Windows\System32\certmgr.msc`

Linux

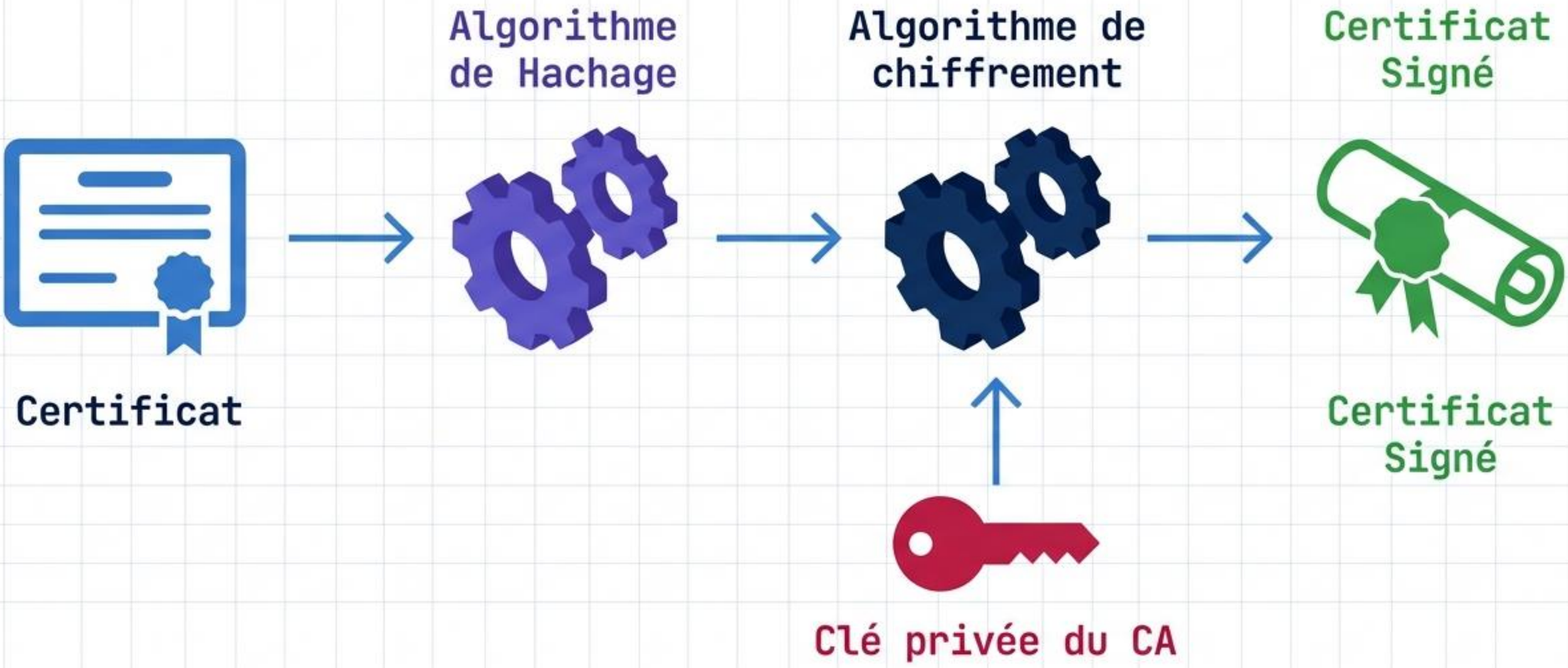
`/etc/ssl/certs/`

Le client vérifie la signature du serveur en comparant la clé publique du CA stockée dans son magasin local avec la signature du certificat reçu.

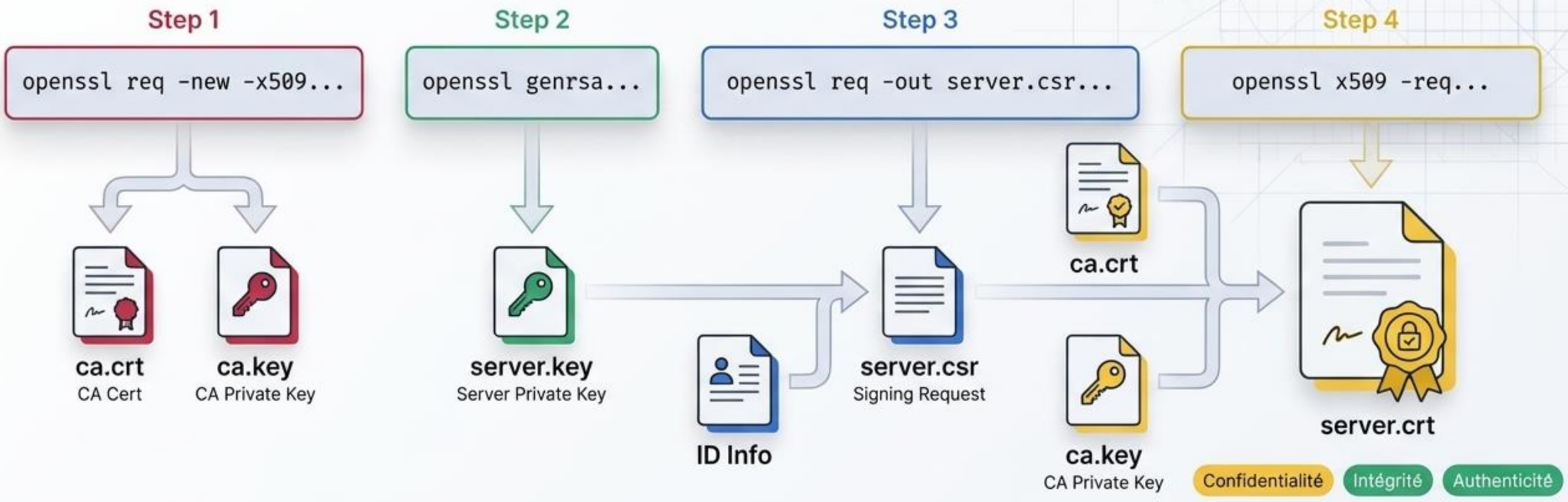
Anatomie d’un Certificat TLS



La Signature d'un Certificat



Le Processus de Création OpenSSL (Auto-Signé)



Décryptage du Fichier .CRT (Encodage Base64)

```
-----BEGIN CERTIFICATE-----
MIIBzzCCAbugAwIBAgIQA/e4h1r8eYl3tK6WkM4aBzANBgkqhkiG9w0BAQsFADAz
MQswCQYDVQQGEwJGUjEZMBcGA1UEChMQSW50ZXJuZXQgV2lkZ2i0czAeFw0yNTAy
MjAwMDAwMDBaFw0yNjAyMTUwMDAwMDBaMD4xCzAJBgNVBAYTAkZSMQ4wDAYDVQQK
EwVNZXw0b24xGzAZBgNVBAMTEjE5Mi4xNjguMS4xOTQwEiMA0GCSGSIb3DQEBAQU
A4IBDwAwggEKAoIBAQC9...[gibberish continues]...6c/mG5rI2Z2aTzK2Y
/5Q9VvN5B7X4C6xH9E1L/8Jv/3P+F2qR4/s/a7T8N6C6/d/4/5/6/7/8/9w==
-----END CERTIFICATE-----
```

Métadonnées et Clé Publique encodées

```
openssl x509 -in server.crt -text -noout
```

```
Issuer:   C=FR, O=Internet Widgits
Validity: Feb 20 2025 - Feb 15 2026
Subject:  C=FR, O=Newton, CN=192.168.1.194
```

Dans les Coulisses Mathématiques (RSA)

```
modulus: 00:df:36:5f:62:3c...
00:df:36:00:df:36:5f:62:3c...
00:0b:35:24:a4:39:45:2a:0a...
00:df:05:08:05:38:24:18:6a...
00:d0:a9:30:43:39:fb:10:64...
00:e8:05:00:11:1f:22:47:2c...
00:db:0a:36:9b:15:ba:56:30...
00:d0:03:00:df:36:5f:62:3c...
00:d2:18:3c:1f:13:ec:32:2d...
00:ed:02:24:3e:22:76:62:b4...
00:d0:3b:00:df:36:5f:62:3c...
...
```

Privice

n = Modulus

Un nombre semi-premier générant la taille de la clé.

Public

e = Exposant Public

Généralement 65537 (0x10001) - utilisé pour chiffrer.

Privé

d = Exposant Privé

Conservé secret – utilisé pour déchiffrer.

Chiffrement $= m^e \pmod{n}$

Déchiffrement $= c^d \pmod{n}$

**Optimisation CRT (Exponent1/2) appliquée pour accélérer le déchiffrement.*

Implémentation MQTTS dans Mosquitto

Côté Broker (/etc/mosquitto/mosquitto.conf)

Port MQTTS sécurisé

```
listener 8883
cafile /ca.crt
certfile /server.crt
keyfile /server.key
```

Côté Client (Terminal)

```
mosquitto_pub -h 192.168.1.25 -p
8883 --cafile /ca.crt -t your/topic
-m 'message'
```

Authentification du certificat serveur

Le Résultat : Le Pipeline Sécurisé

Time	Source	Destination	Protocol	Info
			TCP	secure-mqtt (8883)

```
> Frame 330: … on interface 0, frotool: 324 bytes (2 on interface 0)
> Ethernet II, Src: 001ac5:a82unb (004bd28:4a=3c-ddt:0076118:00 (T218:0:0:00:25:8e)
> Internet Protocol Version 4, Src: 10.10.11
> Transmission Control Protocol, Src 1024-1.522, Sts, R=-mqtt: AC9TW__8883, Enveb: 68
> Data (1024 bytes)
```

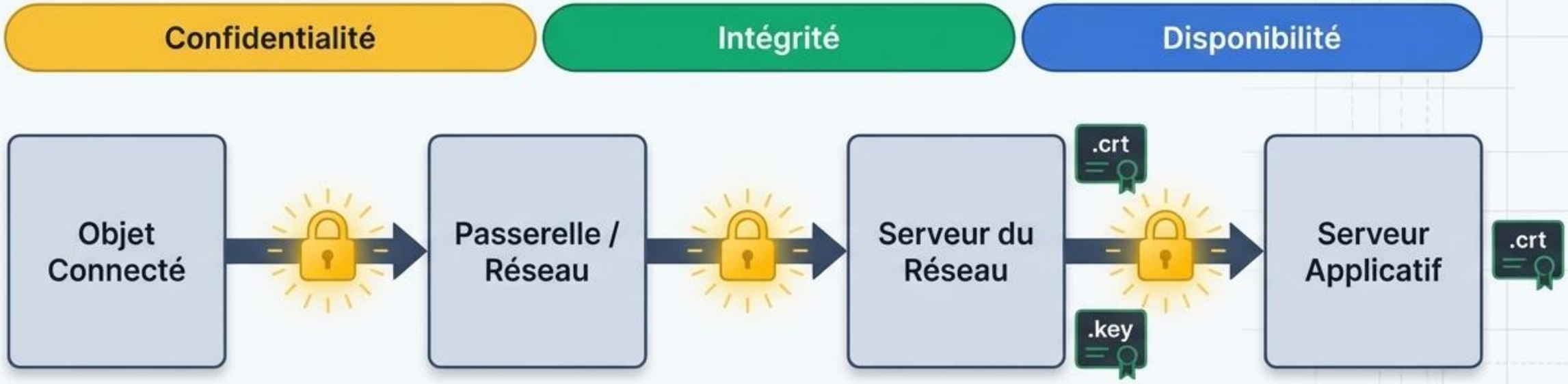
```
0000  1403030001011703030045f6e847af126be31fc1aa6b941b5   ·1······ E·····
0010  1403030001011703030045f6e847af126be31fc1aa6b941b5   ·******* ·a1b3D80
0020  1403030001011703030045f6e847af126be31fc1aa6b941b4   va2003e* 1a80f28f
0030  1403030001011703030045f6e847af126be31fc1aa6b941b6   e32373d* 9a49eb77
0040  1403030001011703030045f6e847af126be31fc1aa6b941b5   a42468h* 98b0m0ao
0050  1403030001011703030045f6e847af126be31fc1aa6b941b4   a24210a* $me503d3
0060  1403030001011703030045f6e847af126be31fc1aa6b941b5   .&inass: undy9022
0070  1403030001011703030045f6e847af126be31fc1aa6b941b    e31710h· *******
```

Ciphertext
(Données Chiffrées)

Grâce à l'implémentation TLS, les mots de passe, les topics et les données de télémétrie sont désormais totalement illisibles pour tout intercepteur. La confidentialité est assurée.

Confidentialité

Synthèse : L'Architecture IoT Sécurisée



De la vulnérabilité en texte clair à une infrastructure cryptographique robuste, la chaîne de valeur garantit désormais la Confidentialité, l'Intégrité et la Disponibilité de bout en bout selon la norme ISO 27001.